Quy định an toàn thông tin

Công ty Cổ phần Công nghệ Lam Tinh · Mã tài liệu: IT-02 · Hiệu lực từ 15/02/2026

Đây là tài liệu mẫu của một công ty hư cấu, được tạo ra để demo dự án chatbot RAG. Mọi tên, số liệu và địa chỉ email trong tài liệu đều không có thật.

Điều 1. Mục đích và phạm vi

Quy định này nhằm bảo vệ thông tin của công ty và khách hàng, áp dụng cho toàn bộ nhân viên, cộng tác viên và nhà thầu có quyền truy cập vào hệ thống của Lam Tinh. Bộ phận An ninh thông tin (Security) chịu trách nhiệm giám sát việc thực hiện.

Điều 2. Phân loại dữ liệu

Dữ liệu của công ty được phân thành 4 cấp độ:

- Công khai: thông tin đã được công bố, ví dụ tài liệu giới thiệu sản phẩm, tin tuyển dụng.
- Nội bộ: thông tin dùng trong công ty, ví dụ quy trình làm việc, thông báo nội bộ.
- Bí mật: thông tin kinh doanh nhạy cảm, ví dụ hợp đồng, báo giá, kế hoạch kinh doanh.
- Tuyệt mật: mã nguồn sản phẩm lõi, dữ liệu cá nhân của khách hàng và thông tin lương của nhân viên.

Dữ liệu Tuyệt mật chỉ được lưu trong thư mục mã hóa trên LT Drive và không được gửi ra ngoài công ty qua email.

Điều 3. Mật khẩu

Mật khẩu phải có độ dài tối thiểu 12 ký tự, bao gồm chữ hoa, chữ thường, chữ số và ký tự đặc biệt. Mật khẩu phải được thay đổi định kỳ 90 ngày một lần và không được trùng với 5 mật khẩu gần nhất. Tài khoản sẽ bị khóa tạm thời nếu nhập sai mật khẩu 5 lần trong vòng 15 phút.

Nhân viên sử dụng trình quản lý mật khẩu do công ty cung cấp và tuyệt đối không chia sẻ mật khẩu cho người khác, kể cả đồng nghiệp hoặc bộ phận IT.

Điều 4. Xác thực đa yếu tố

Xác thực đa yếu tố (MFA) là bắt buộc khi đăng nhập email, VPN, LT Drive và hệ thống quản lý mã nguồn. Nhân viên sử dụng ứng dụng xác thực (authenticator) trên điện thoại; công ty không sử dụng mã xác thực qua SMS.

Điều 5. Sử dụng máy tính của công ty

- Máy tính phải bật chế độ tự động khóa màn hình sau 5 phút không sử dụng.
- Ổ cứng phải được mã hóa bằng BitLocker (Windows) hoặc FileVault (macOS).
- Chỉ cài phần mềm trong danh mục được phép; phần mềm khác phải gửi yêu cầu qua IT Helpdesk.
- Không sử dụng USB hoặc ổ cứng di động để sao chép dữ liệu, trừ khi được IT cấp phép tạm thời với thời hạn tối đa 7 ngày.

Điều 6. Thiết bị cá nhân

Nhân viên chỉ được truy cập email và LT Chat trên điện thoại cá nhân sau khi cài đặt ứng dụng quản lý thiết bị LT Secure. Không được lưu dữ liệu Bí mật hoặc Tuyệt mật trên thiết bị cá nhân.

Điều 7. Làm việc từ xa và mạng Internet

Khi làm việc ngoài văn phòng, nhân viên bắt buộc kết nối VPN của công ty trước khi truy cập hệ thống nội bộ. Không sử dụng Wi-Fi công cộng khi chưa bật VPN và không xử lý dữ liệu Tuyệt mật tại nơi công cộng.

Điều 8. Email lừa đảo (phishing)

Khi nhận được email đáng ngờ, nhân viên không mở tệp đính kèm, không nhấp vào đường link và báo cáo bằng nút "Report Phishing" trên ứng dụng email hoặc chuyển tiếp email tới phishing@lamtinh.example.

Bộ phận Security tổ chức diễn tập phishing mỗi quý một lần. Nhân viên nhấp vào đường link trong bài diễn tập phải hoàn thành lại khóa đào tạo an toàn thông tin trong vòng 7 ngày.

Điều 9. Sử dụng công cụ trí tuệ nhân tạo (AI)

Nhân viên không được nhập mã nguồn, dữ liệu khách hàng hoặc bất kỳ dữ liệu Bí mật, Tuyệt mật nào vào các công cụ AI công cộng như chatbot hoặc dịch vụ dịch thuật trực tuyến. Khi cần dùng AI cho công việc, nhân viên sử dụng nền tảng AI nội bộ LT Assistant đã được bộ phận Security phê duyệt.

Điều 10. Báo cáo sự cố an toàn thông tin

Khi phát hiện sự cố như mất thiết bị, lộ mật khẩu hoặc nghi ngờ máy tính nhiễm mã độc, nhân viên phải báo cáo trong vòng 1 giờ qua hotline IT (máy lẻ 9999) hoặc email security@lamtinh.example. Trường hợp mất máy tính xách tay, bộ phận IT sẽ khóa thiết bị và xóa dữ liệu từ xa.

Điều 11. Đào tạo

Nhân viên mới phải hoàn thành khóa đào tạo nhận thức an toàn thông tin trong 2 tuần đầu tiên và tham gia đào tạo lại hằng năm. Bài kiểm tra cuối khóa cần đạt tối thiểu 80% số điểm.

Điều 12. Quản lý quyền truy cập

Quyền truy cập được cấp theo nguyên tắc tối thiểu cần thiết cho công việc và được rà soát 6 tháng một lần. Khi nhân viên nghỉ việc, toàn bộ tài khoản sẽ bị vô hiệu hóa trong vòng 24 giờ kể từ thời điểm chấm dứt hợp đồng.

Điều 13. Xử lý vi phạm

- Vi phạm lần đầu: nhắc nhở bằng văn bản.
- Vi phạm lần thứ hai: khiển trách và không xét thưởng hiệu suất của kỳ đánh giá đó.
- Vi phạm nghiêm trọng, ví dụ làm lộ dữ liệu Tuyệt mật: có thể bị chấm dứt hợp đồng lao động.